Отчёт по лабораторной работе №2

Тестирование на проникновение в инфраструктуру предприятия

Выполнили: Zetta

Содержание

1 1. Цель работы **5**

2 2. Легенда атаки **6**

3 3. Разведка и обнаружение веб-сервера **7**
3.1 3.1. Обнаружение узлов и сервисов 7
3.2 3.2. Исследование WordPress 9

4 4. Получение доступа к веб-серверу **11**
4.1 4.1. Настройка модуля 11
4.2 4.2. Получение Meterpreter-сессии 11

5 5. Переход во внутреннюю сеть **13**
5.1 5.1. Обнаружение внутреннего интерфейса и маршрута 13
5.2 5.2. Настройка SOCKS-прокси 15

6 6. Доступ к MariaDB и получение флага **18**

7 7. Выводы **20**

Список иллюстраций

3.1 Рис. 1 — Обнаружение активных узлов; 195.239.174.12 исключён из проверки 8
3.2 Рис. 2 — Сервисы веб-сервера: HTTP открыт, HTTPS фильтруется . 8
3.3 Рис. 3 — Публикация «IT is magic» на портале portal.ampire.corp . 9
3.4 Рис. 4 — Результаты сканирования WordPress и обнаруженные плагины 10
3.5 Рис. 5 — Найденный модуль проверки уязвимости wpDiscuz 10

4.1 Рис. 6 — Параметры модуля для проверки WordPress 11
4.2 Рис. 7 — Успешное открытие Meterpreter-сессии 12
4.3 Рис. 8 — Повышение исходной сессии до расширенной Meterpreter-сессии 12

5.1 Рис. 9 — Внутренний интерфейс и таблица маршрутизации веб-сервера 14
5.2 Рис. 10 — Добавление маршрута к сети 10.10.10.0/24 14
5.3 Рис. 11 — Результаты обнаружения узлов внутренней сети 15
5.4 Рис. 12 — Параметры SOCKS5-прокси Metasploit 16
5.5 Рис. 13 — Настройка Proxychains на SOCKS5 127.0.0.1:1080 16
5.6 Рис. 14 — Локальный SOCKS-прокси слушает порт 1080 16
5.7 Рис. 15 — Фоновая задача SOCKS-прокси и активные сессии 17

6.1 Рис. 16 — Проверка доступности MariaDB на 10.10.10.30 через Proxychains 18
6.2 Рис. 17 — Таблица fpawq в базе Flag; имя таблицы является флагом 19

Список таблиц

Тренажёр Ampire, сценарий ЛР2 [НПИ-01-23 Zetta]

1 1. Цель работы

Исследовать в учебной инфраструктуре Ampire путь от внешнего веб-приложения к внутреннему сервису базы данных, получить доступ к MariaDB и определить контрольное значение сценария.

2 2. Легенда атаки

- На внешнем веб-сервере предприятия размещён портал WordPress с плагином wpDiscuz.
- Через уязвимость плагина в рамках лабораторного стенда получается сессия на веб-сервере.
- Скомпрометированный веб-сервер имеет доступ во внутреннюю сеть `10.10.10.0/24`.
- Через маршрут и SOCKS-прокси исследуется доступность внутренних сервисов.
- На сервере MariaDB проверяется доступ к базе `Flag` и извлекается контрольное значение.

Все действия выполнялись исключительно в учебном стенде. Внешняя разведка проводилась в диапазоне `195.239.174.0/24` с исключением адреса `195.239.174.12`, как предписано условиями лабораторной работы.

3 3. Разведка и обнаружение веб-сервера

3.1 3.1. Обнаружение узлов и сервисов

В разрешённом внешнем диапазоне обнаружены узлы стенда, в том числе веб-сервер `195.239.174.25` (`portal.ampire.corp`). Проверка сервисов показала доступность HTTP на TCP/80; HTTPS на TCP/443 был отфильтрован.

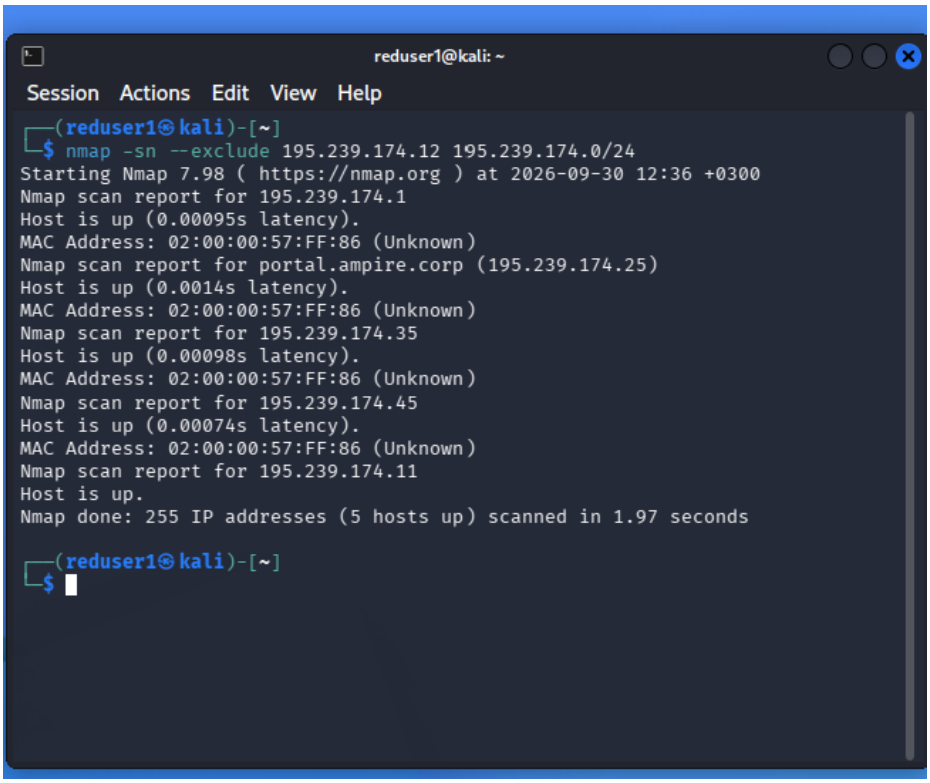


Рисунок 3.1: Рис. 1 — Обнаружение активных узлов; 195.239.174.12 исключён из проверки

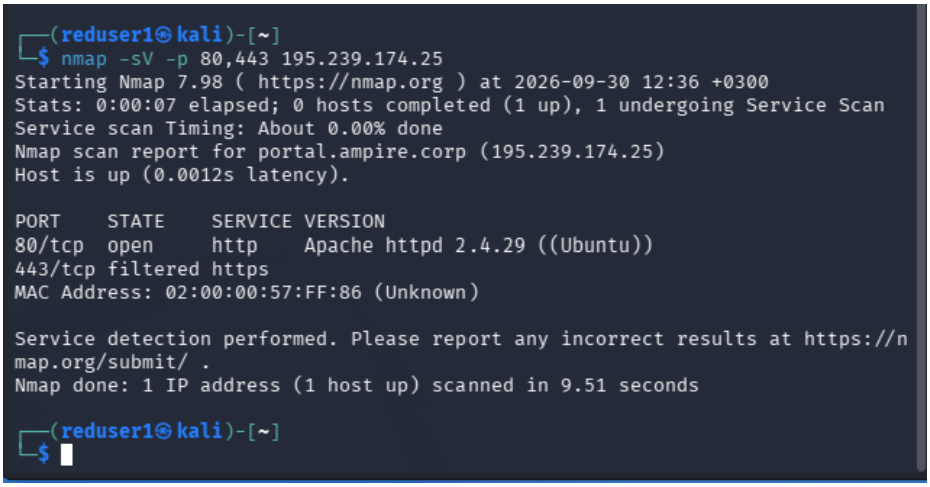


Рисунок 3.2: Рис. 2 — Сервисы веб-сервера: HTTP открыт, HTTPS фильтруется

3.2 3.2. Исследование WordPress

На портале обнаружена публикация WordPress «IT is magic» по адресу `/index.php/2021/07/26/hello-world/`.

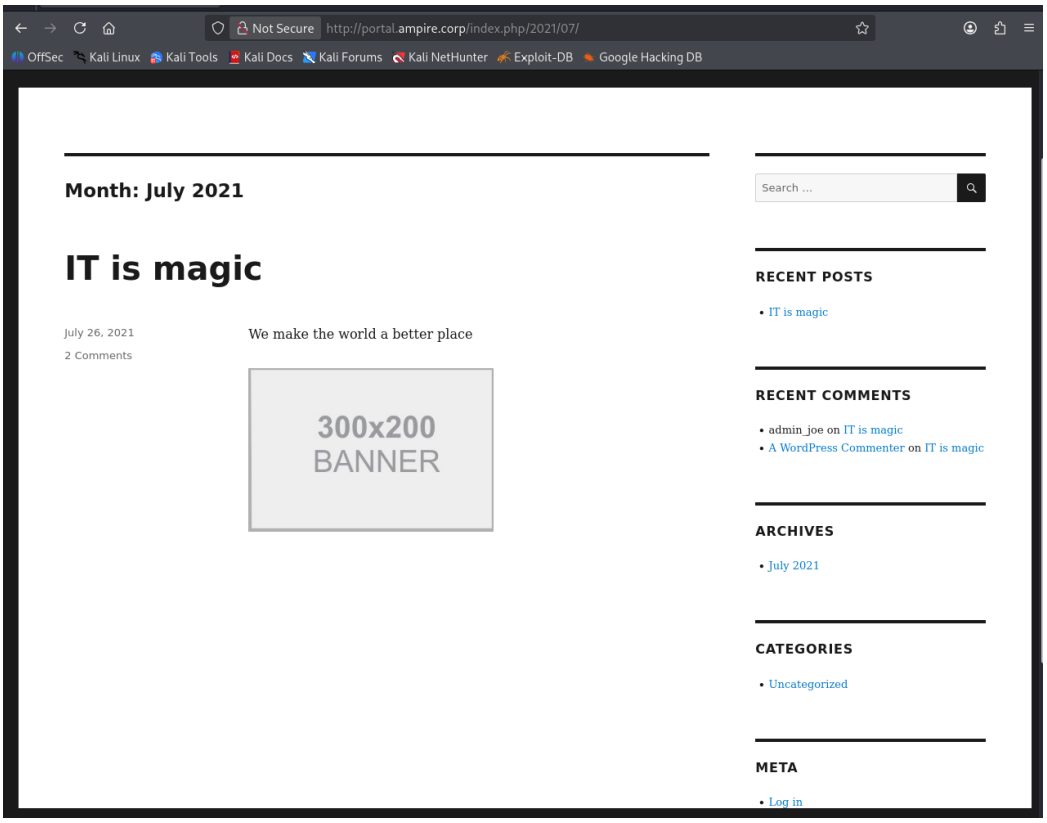


Рисунок 3.3: Рис. 3 — Публикация «IT is magic» на портале portal.ampire.corp

Сканер Metasploit определил WordPress версии 5.8.2 и плагин wpDiscuz версии 7.0.2. Поиск модулей Metasploit показал наличие модуля проверки уязвимости неаутентифицированной загрузки файла в wpDiscuz.

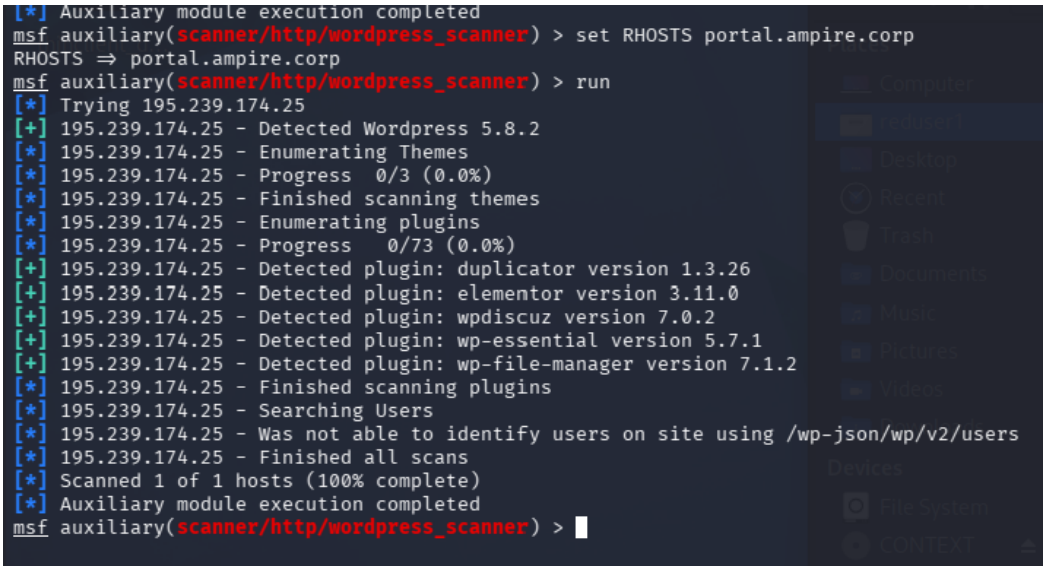


Рисунок 3.4: Рис. 4 — Результаты сканирования WordPress и обнаруженные плагины

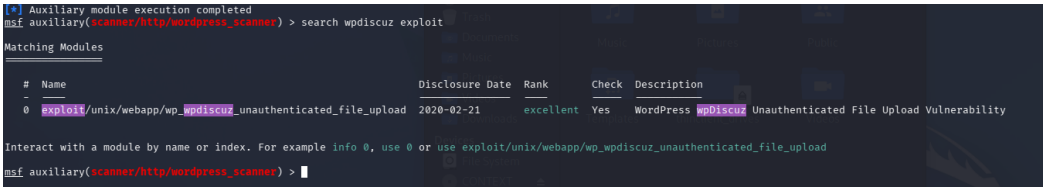


Рисунок 3.5: Рис. 5 — Найденный модуль проверки уязвимости wpDiscuz

4 4. Получение доступа к веб-серверу

4.1 4.1. Настройка модуля

Для проверки в рамках лабораторного стенда выбран модуль `exploit/unix/webapp/wp_wpdis`
Были заданы целевой адрес `195.239.174.25`, виртуальный хост `portal.ampire.corp`, путь к публикации и адрес интерфейса Kali для обратного соединения.

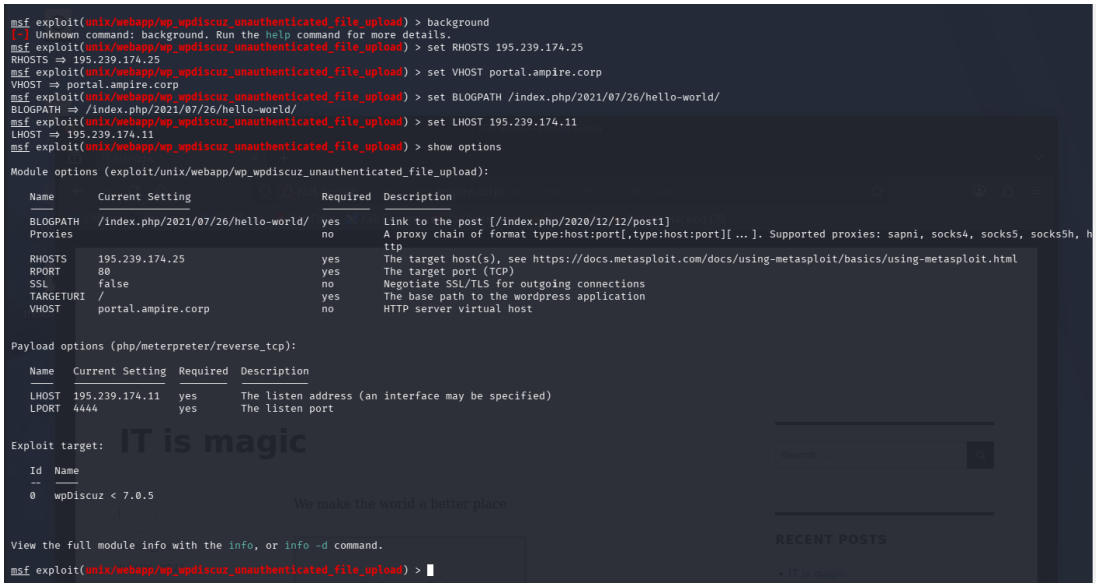


Рисунок 4.1: Рис. 6 — Параметры модуля для проверки WordPress

4.2 4.2. Получение Meterpreter-сессии

Автоматическая проверка сообщила, что цель выглядит уязвимой. После запуска модуля была открыта сессия Meterpreter от имени пользователя

веб-сервера `www-data`. Затем сессия была преобразована в расширенную Meterpreter-сессию.

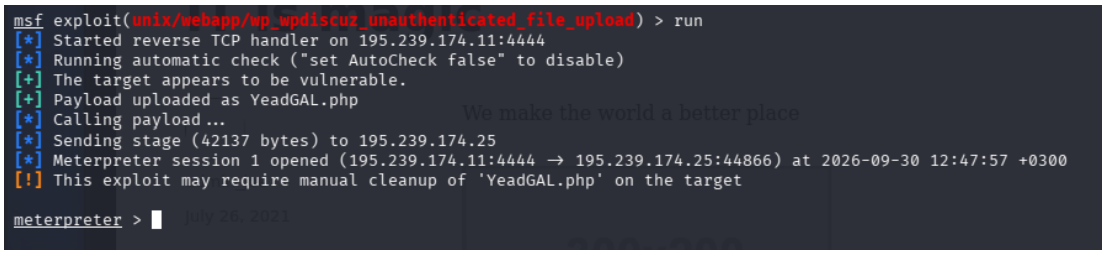


Рисунок 4.2: Рис. 7 — Успешное открытие Meterpreter-сессии

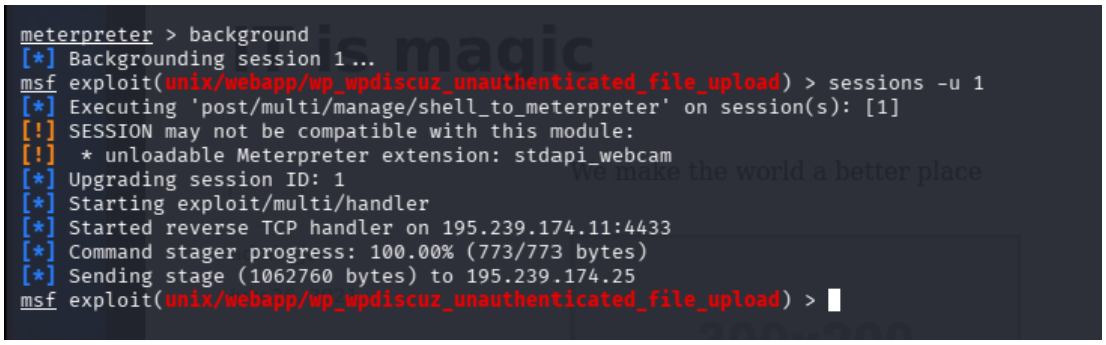


Рисунок 4.3: Рис. 8 — Повышение исходной сессии до расширенной Meterpreter-сессии

5 5. Переход во внутреннюю сеть

5.1 5.1. Обнаружение внутреннего интерфейса и маршрута

На веб-сервере обнаружен интерфейс `ens3` с адресом `10.10.10.25/24` и шлюзом `10.10.10.254`. Через сессию добавлен маршрут к сети `10.10.10.0/24`. Проверка внутреннего сегмента обнаружила несколько активных адресов, в том числе `10.10.10.30` и `10.10.10.45`.

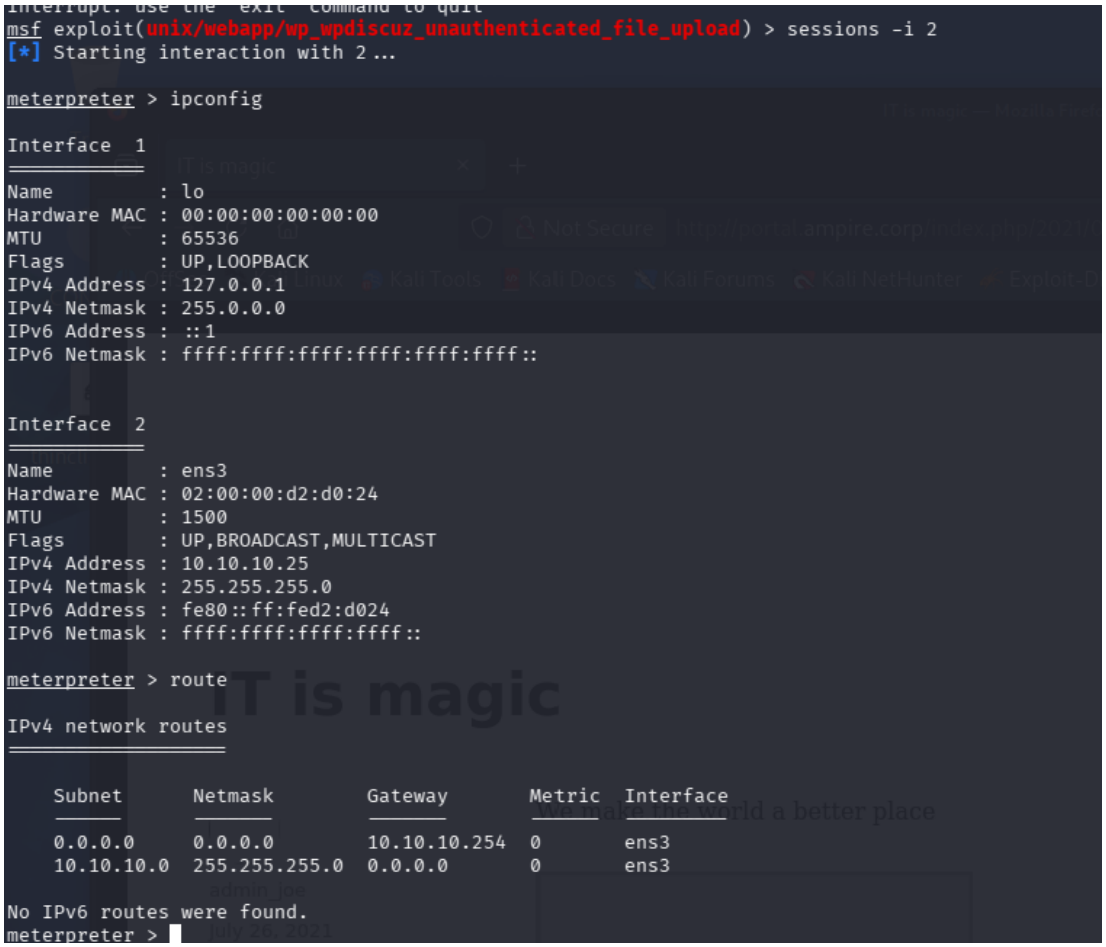


Рисунок 5.1: Рис. 9 — Внутренний интерфейс и таблица маршрутизации веб-сервера

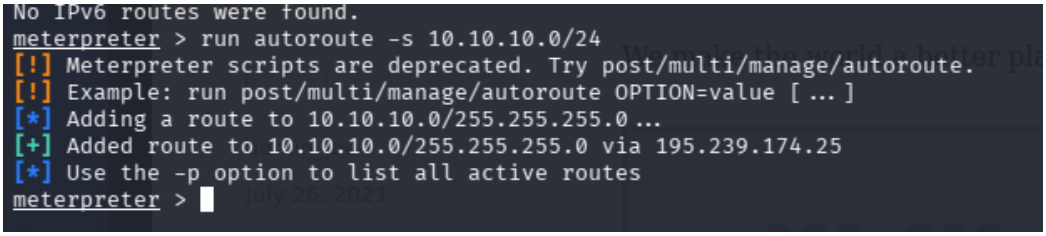


Рисунок 5.2: Рис. 10 — Добавление маршрута к сети 10.10.10.0/24

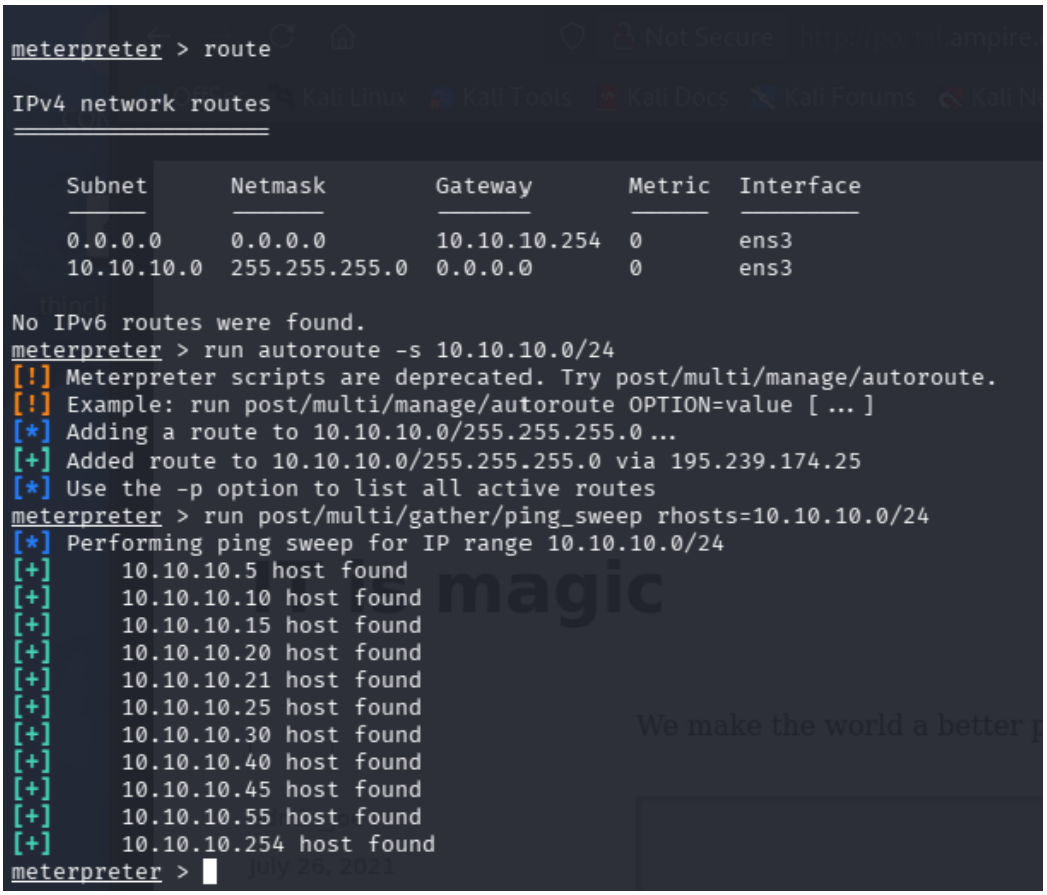


Рисунок 5.3: Рис. 11 — Результаты обнаружения узлов внутренней сети

5.2 5.2. Настройка SOCKS-прокси

Для доступа к внутренним сервисам запущен SOCKS5-прокси Metasploit на `127.0.0.1:1080`. Proxychains настроен использовать этот локальный прокси. Прослушивание порта и наличие фоновой задачи прокси были проверены отдельно.

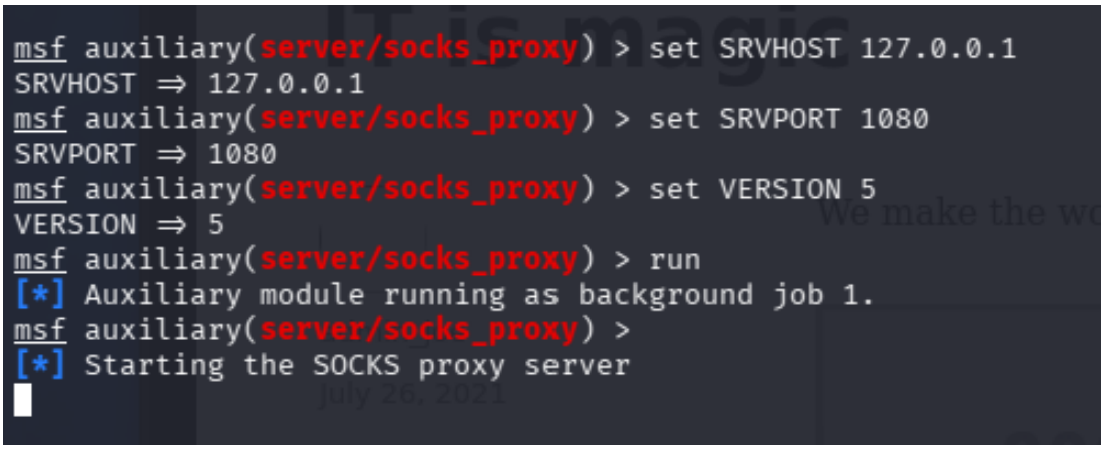


Рисунок 5.4: Рис. 12 — Параметры SOCKS5-прокси Metasploit

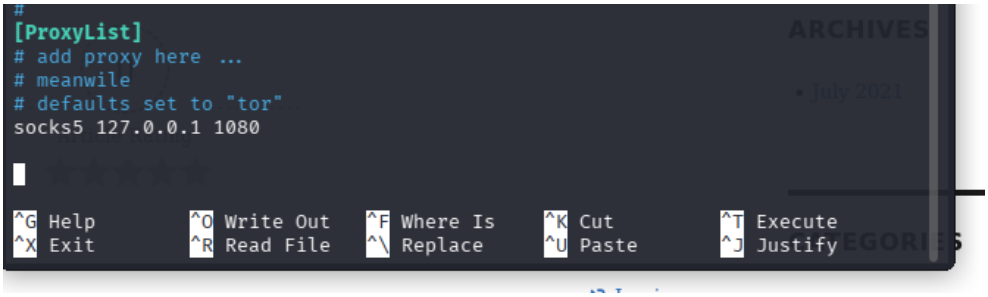


Рисунок 5.5: Рис. 13 — Настройка Proxychains на SOCKS5 127.0.0.1:1080



Рисунок 5.6: Рис. 14 — Локальный SOCKS-прокси слушает порт 1080

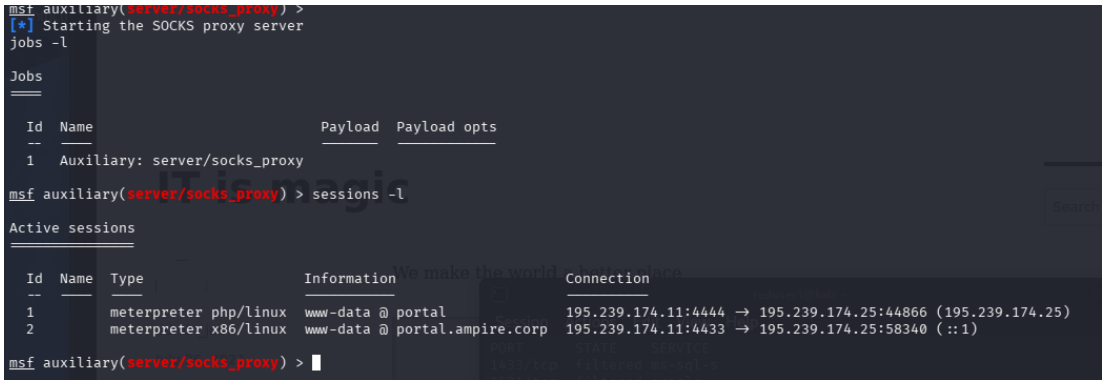


Рисунок 5.7: Рис. 15 — Фоновая задача SOCKS-прокси и активные сессии

6 6. Доступ к MariaDB и получение флага

Проверка TCP-доступности через Proxychains показала открытый порт 3306 на узлах `10.10.10.30` и `10.10.10.45`. На узле `10.10.10.45` аутентификация не прошла. Успешное подключение к MariaDB было установлено на сервере `10.10.10.30`.

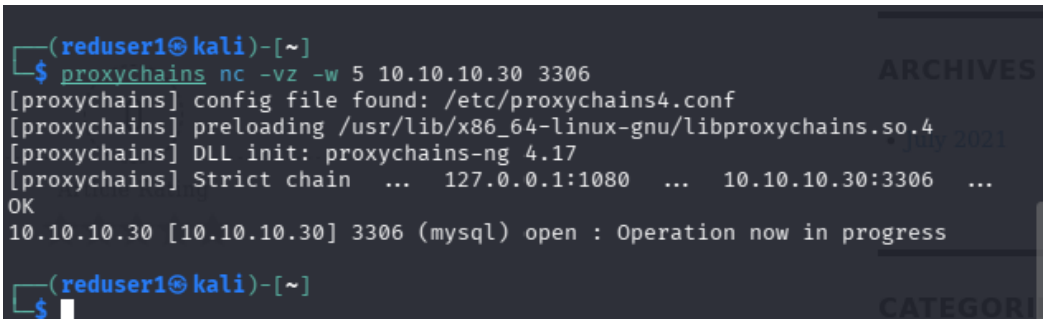


Рисунок 6.1: Рис. 16 — Проверка доступности MariaDB на 10.10.10.30 через Proxychains

В списке баз данных сервера присутствовала база `Flag`. После её выбора команда просмотра таблиц показала таблицу `fpawq`. В таблице нет строк; согласно завершающему примеру методических указаний контрольным значением является имя таблицы.

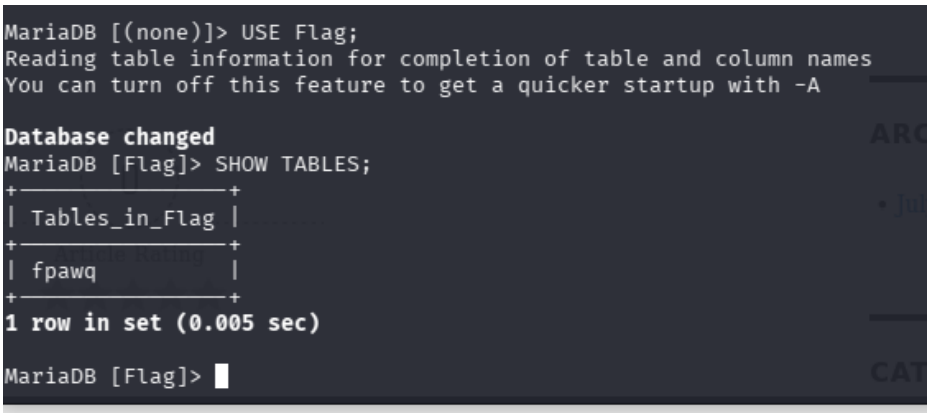


Рисунок 6.2: Рис. 17 — Таблица fpawq в базе Flag; имя таблицы является флагом

Полученный флаг: `fpawq`**.**

7 7. Выводы

- В разрешённом внешнем диапазоне обнаружен портал WordPress `portal.ampire.corp`.
- Сканирование выявило WordPress 5.8.2 и wpDiscuz 7.0.2; в учебном стенде получена Meterpreter-сессия.
- Обнаружена внутренняя сеть `10.10.10.0/24`; для проверки сервисов настроены маршрут и SOCKS5-прокси.
- Через Proxychains подтверждена доступность MariaDB на `10.10.10.30:3306` и получен доступ к базе `Flag`.
- Контрольное значение лабораторного сценария — `fpawq`.

Работа показала, что уязвимость внешнего веб-компонента в сочетании с доступом сервера приложений во внутреннюю сеть может создать путь к критичным сервисам. Для снижения риска необходимы своевременное обновление CMS и плагинов, сегментация сети, ограничение доступа к СУБД и минимальные привилегии веб-процессов.